WAF — Web Application Firewall

Complete Security Guide — Types • Bypass Techniques • Tools & Mitigation

Contents

- What is WAF & How It Works?
- Types of WAF
- Advantages of WAF
- WAF Vendors
- WAF vs Firewall & IPS
- WAF Mitigation
- Techniques to Bypass WAF
- Awesome Tools

1. What is WAF?

A **Web Application Firewall (WAF)** is an application firewall for HTTP applications. A WAF operates through a set of rules often called policies. These policies aim to protect against vulnerabilities in the application by filtering out malicious traffic.

By deploying a WAF in front of a web application, a shield is placed between the web application and the Internet. While a proxy server protects a client machine's identity by using an intermediary, a WAF is a type of **reverse-proxy**, protecting the server from exposure by having clients pass through the WAF before reaching the server.

It protects web applications from a variety of application layer attacks such as cross-site scripting (XSS), SQL injection, and cookie poisoning, among others. Attacks to apps are the leading cause of breaches — they are the gateway to your valuable data.

2. How It Works?

- A WAF protects your web apps by **filtering, monitoring, and blocking** any malicious HTTP/S traffic traveling to the web application, and prevents any unauthorized data from leaving the app. It does this by adhering to a set of policies that help determine what traffic is malicious and what traffic is safe.

- WAFs can come in the form of **software, an appliance, or delivered as-a-service**. Policies can be customized to meet the unique needs of your web application. Advances in machine learning enable some WAFs to update automatically.

3. Types of WAF

A WAF can be implemented one of three different ways, each with its own benefits and shortcomings:

- ❖ **Network-Based WAF (Hardware-Based):** Installed locally to minimize latency. Most expensive option and requires storage and maintenance of physical equipment.
- ❖ **Host-Based WAF (Software-Based):** Fully integrated into an application's software. Less expensive than network-based but requires local server resources, implementation complexity, and maintenance costs.
- ❖ **Cloud-Based WAF:** Affordable and easy to implement via DNS change. Minimal upfront cost with monthly or annual billing. Consistently updated to protect against the newest threats without any additional work.

---

4. Advantages of WAF

A WAF offers greater visibility into sensitive application data communicated using the HTTP layer. It can prevent application layer attacks that bypass traditional network firewalls:

- **Cross-Site Scripting (XSS):** Enables attackers to inject and execute malicious scripts in another user's browser.
- **SQL Injection:** Affects any application using an SQL database and enables attackers to access and potentially change sensitive data.
- **Web Session Hacking:** Enables attackers to hijack a session ID and masquerade as an authorized user.
- **DDoS Attacks:** Overwhelm a network by flooding it with traffic until it cannot serve its users.

A WAF can also defend web-based applications without necessarily having access to the source code. Cloud WAFs provide quick **virtual patching** solutions that enable users to rapidly adapt to newly detected threats.

---

5. Popular WAF Vendors

Some of the most widely used WAF vendors in the industry:

- Cloudflare WAF
- AWS WAF
- Imperva
- Akamai Kona Site Defender
- Microsoft Azure WAF
- F5 Advanced WAF

- Barracuda WAF
- Fortinet FortiWeb
- Citrix WAF
- Sucuri WAF
- Radware AppWall
- Alibaba Cloud WAF

---

6. WAF vs Firewall & IPS

- **IPS (Intrusion Prevention System):** Broadly focused, signature and policy based. Protects layers 3 and 4 (network and session). Checks for known vulnerabilities based on signature database.
- **NGFW (Next-Generation Firewall):** Monitors outbound traffic to the Internet. Protects the user (vs the web application). Adds URL filtering, anti-virus, and its own IPS. Acts as a forward proxy.
- **WAF (Web Application Firewall):** Protects the application layer (Layer 7). Specifically designed to analyze each HTTP/S request. Acts as a reverse proxy. First line of defense against OWASP Top 10.

OWASP Top 10 that WAF protects against:

- Injection attacks
- Broken Authentication
- Sensitive data exposure
- XML External Entities (XXE)
- Broken Access control
- Security misconfigurations
- Cross Site Scripting (XSS)
- Insecure Deserialization

---

7. WAF Mitigation Methods

There are three primary methods a WAF uses to detect and prevent web attacks:

❖ **Deny/Allow Requests:** Requests are either denied or allowed based on available information such as IP address or HTTP OPTIONS/METHODS. Similar to the traditional doorway model used by network firewalls.

❖ **Signatures:** Two kinds — user-defined and vendor-managed. Anti-virus, anti-malware, IPS/IDS, and WAF all rely on signatures to quickly scan for evidence of known attacks.

❖ **Inspection:** Compares request information against known good/bad strings and values. Most important capability for HTTP applications. Can inspect both known headers and payload content.

---

8. Techniques to Bypass WAF

- **Case Toggling:** Combine upper and lower case characters for efficient payloads.

```
<ScrIpT>confirm()</sCRiPt>
```

- **Using Comments:** Comments obfuscate standard payload vectors.

```
<!--><script>confirm/**/()/**/</script>
```

```
sELecT * FrOm all_tables whERe OWNER = 'DATABASE_NAME'
```

- **Null Character Injection:** Inject %00 before malicious input. WAFs ignore everything after the null but pass the entire string to the web server.

- **Inline Comments:** Insert comments in the middle of attack strings.

```
Blocked: /?id=1+union+select+1,2,3--
```

```
Bypassed: /?id=1+un/**/ion+sel/**/ect+1,2,3--
```

- **HTTP Parameter Pollution:** Supply multiple parameter=value sets of the same name to confuse the WAF.

```
http://example.com?id=1&id=' or '1'='1
```

- **URL Encoding (Hex):** Use hex equivalent for characters such as %27 for ' or %3c for <.

```
Blocked: <svG/x=">"/oNloaD=confirm()//
```

```
Bypassed: %3CsvG%2Fx%3D%22%3E%22%2FoNloaD%3Dconfirm%28%29%2F%2F
```

- **Double Encoding:** Bypass poorly developed filters with no recursion.

```
Standard: <script>alert()</script>
```

```
Obfuscated: %253Cscript%253Ealert()%253C%252Fscript%253E
```

- **Line Breaks (CR/LF):** Break firewall regex and bypass string matching.

```
Standard: <iframe src=javascript:confirm(0)>
```

```
Obfuscated: <iframe
src="%0Aj%0Aa%0Av%0Aa%0As%0Ac%0Ar%0Ai%0Ap%0At%0A%3Aconfirm(0)">
```

- **Junk Characters:** Confuse regex-based firewalls with added junk characters.

```
Standard: <script>alert()</script>
```

```
Obfuscated: <script>+-+-1-+-+alert(1)</script>
```

- **Keyword Splitting:** Insert special chars removed by WAF — SEL<ECT becomes SELECT.

- **Replaced Keywords:** Wrap keyword around itself — SELSELECTECT becomes SELECT after inner removed.

- **Buffer Overflow:** WAFs are applications too — a crash may cause WAF to fail open.

- **Ephemeral SSL (DHE/EDH):** Abuse perfect forward secrecy — WAF cannot decrypt DHE/EDH sessions.
- **WAF Auto-Learning Abuse:** Trigger n violations from different IPs to un-learn a rule.
- **Data URIs:** Encode offending strings as data URIs — useful for XSS client-side attacks.

---

9. Awesome Tools

WAFW00F – Ultimate WAF fingerprinting tool with the largest fingerprint database.
github.com/enablesecurity/wafw00f

IdentYwaf – Blind WAF detection tool using unique fingerprint-based identification method.
github.com/stamparm/identywaf

WhatWaf – Detect and identify a firewall protecting a web application.
github.com/Ekultek/WhatWaf

GoTestWAF – Tool to test a WAF's detection logic and bypass capabilities.
github.com/wallarm/gotestwaf

WAFNinja – Smart tool that fuzzes and suggests bypasses for a given WAF.
github.com/khalilbijjou/wafninja

CloudFail – Tactical recon tool to find original IP address behind Cloudflare WAF.
github.com/m0rtem/CloudFail

BypassWAF – Bypass firewalls by abusing DNS history to find old DNS A records.
github.com/vincentcox/bypass-firewalls-by-DNS-history

W3af – Web Application Attack and Audit Framework.
github.com/andresriancho/w3af

SQLMap Tamper Scripts – Tamper scripts obfuscate payloads which may evade WAFs.
github.com/sqlmapproject/sqlmap

Bypass WAF BurpSuite Plugin – Adds headers to make requests appear from internal network.
portswigger.net/bappstore/ae2611da3bbc4687953a1f4ba6a4e04c

abuse-ssl-bypass-waf – Finds supported SSL/TLS ciphers and helps in evading WAFs.
github.com/LandGrey/abuse-ssl-bypass-waf

Lightbulb Framework – WAF testing suite written in Python.
github.com/lightbulb-framework/lightbulb-framework

WAFBench – WAF performance testing suite by Microsoft.
github.com/microsoft/wafbench

Framework for Testing WAFs (FTW) – OWASP CRS team framework for rigorous WAF rule tests.
github.com/coreruleset/ftw

TEAM CYBEROPS
MONITOR AND PROTECT